

Cloud Security Risk Assessment & GRC Simulation (Azure)

Evidence-based assessment of an Azure-hosted Windows Server virtual machine

Prepared by	Iker Paster
Assessment type	Point-in-time, non-exploitative GRC simulation
Environment	Microsoft Azure personal lab
Frameworks	NIST CSF 2.0 and CIS Controls v8.1
Scope	GRC-WIN-VM01 and supporting Azure controls
Overall inherent posture	Medium-High

PORTFOLIO USE: Authorized personal lab. No active exploitation was performed. This report is not a formal audit or compliance certification.

1. Executive Summary

This report documents a cloud security risk assessment of one Azure-hosted Windows Server virtual machine. The review covered remote access, local administrative privileges, endpoint configuration, patch management, logging, monitoring, Defender recommendations, and subscription-level authorization.

Metric	Result	Interpretation
Risks recorded	5	Four High and one Medium
Highest inherent score	16/25	Public RDP exposure
Validated mitigations	1	RDP restricted to trusted IPv4 /32
R-01 residual score	8/25	Medium; additional hardening remains

Key result: The NSG rule for TCP/3389 was changed from source Any to a trusted public IPv4 /32. Likelihood was reassessed from 4 to 2, while impact remained 4, reducing R-01 from 16 (High) to 8 (Medium).

Overall inherent risk posture: Medium-High. The current overall posture remains Medium-High after the RDP restriction because other High risks remain untreated. The target residual posture is Medium after the planned identity, monitoring, endpoint-hardening, patch, and RBAC actions are completed.

2. Scope and Environment

Item	Assessed environment
Cloud provider	Microsoft Azure
Resource group	GRC-Lab
Virtual machine	GRC-WIN-VM01
Operating system	Windows Server 2022 Datacenter: Azure Edition
Region	UAE North
Access path	Native RDP over TCP/3389
Administrative identity	Local account azureadmin

In scope: VM, NIC, public IP, NSG, local administrator identity, Windows security/update configuration, local event logs, Azure monitoring posture, Defender recommendations, and subscription RBAC relevant to the VM.

Out of scope: exploitation, password attacks, vulnerability scanning, production workloads, business applications, data classification, and unrelated Azure resources.

3. Methodology and Rating Model

Step	Activity
1	Define scope and identify cloud, identity, network, endpoint, logging, and governance assets.
2	Collect configuration evidence from Azure Portal and Windows without exploitation.
3	Connect realistic threats to observed weaknesses and document business impact.
4	Score each risk using Likelihood x Impact on a 1-5 scale.
5	Map controls to NIST CSF 2.0 and CIS Controls v8.1.
6	Implement and validate the priority NSG mitigation.

Risk matrix

Impact / Likelihood	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

Rating thresholds: 1-4 Low; 5-9 Medium; 10-16 High; 17-25 Critical. Every score includes a written justification to support auditability.

Likelihood considers exposure, attack frequency, ease of exploitation, and existing controls. Impact considers confidentiality, integrity, availability, privilege gained, disruption, compliance, and reputation.

4. Asset Inventory

Category	Asset	Why it matters
Compute	GRC-WIN-VM01	Hosts the Windows operating system and services
Network	Public IP and NSG	Define internet reachability and permitted flows
Network	NIC and virtual network	Connect the VM to the Azure network
Identity	Local azureadmin	Provides full local administrative control
Authorization	Subscription Owner	Grants broad management and access-assignment capability
Logging	Windows Security log	Provides local security telemetry
Monitoring	Azure Monitor / Defender	Provides centralized visibility, alerts, and recommendations

5. Risk Register

ID	Risk scenario	L	I	Score	Rating	Treatment
R-01	Publicly reachable RDP enables automated credential attacks	4	4	16	High	Partially mitigated
R-02	Local administrator credential compromise provides full VM control	3	5	15	High	Planned
R-03	Endpoint and update configuration gaps increase exploitation risk	3	4	12	High	Planned
R-04	Standing subscription Owner access creates privilege concentration	2	5	10	High	Accepted for lab
R-05	Missing centralized alerting delays detection and response	3	3	9	Medium	Planned

Scoring justification

Risk	Likelihood rationale	Impact rationale
R-01	Internet-reachable administrative ports are routinely scanned and targeted.	Successful authentication would provide interactive remote access.
R-02	Credential compromise is possible but was not observed.	The account is a local administrator with full VM control.
R-03	Configuration gaps create plausible exposure; no specific exploitable CVE was verified.	Exploitation or control impairment could significantly affect the VM.
R-04	Misuse is less likely in a controlled personal lab.	Owner permissions can affect resources and access assignments at subscription scope.
R-05	Adverse activity is possible in an internet-connected environment.	Local logs provide evidence, but absent centralized alerting delays response.

Important interpretation: a public IP alone does not prove exposure. The exposure conclusion is supported by the NSG evidence showing TCP/3389 allowed from Any source.

6. Detailed Findings

R-01 - Broad RDP exposure (High, 16/25)

The baseline NSG rule allowed TCP/3389 from any source to a VM with a public IP. This provides a common entry path for automated credential attacks. Restricting the source to a trusted /32 reduced exposure but did not eliminate public RDP risk.

R-02 - Privileged local account (High, 15/25)

The enabled azureadmin account is a member of the local Administrators group. The assessment did not establish that MFA protects this local RDP path. Credential compromise would therefore have critical system-level impact.

R-03 - Endpoint and patch configuration gaps (High, 12/25)

Windows Update reported no updates available at capture time, but automatic updates were turned off. Windows Security showed Tamper Protection and potentially unwanted application blocking disabled. These findings do not prove a missing patch or active compromise.

R-04 - Subscription privilege concentration (High, 10/25)

One account held the Owner role at subscription scope. This is acceptable for a personal lab when documented, but production environments should implement least privilege, separation of duties, time-bound elevation, and recurring access reviews.

R-05 - Detection and monitoring gap (Medium, 9/25)

Windows Security events were available locally, while Azure Monitor alerts and enhanced guest monitoring were not configured. This can delay detection, triage, containment, and evidence collection.

7. Control Mapping

Risk	Safeguard	Type	NIST CSF 2.0	CIS v8.1
R-01	Restrict ingress; prefer Bastion, VPN/private access, or JIT	Preventive	PR.PS; PR.AA	4.4; 12.2
R-02	Require MFA and centralize authentication	Preventive	PR.AA	6.4; 6.5; 6.7
R-03	Secure endpoint configuration and automated patching	Preventive / Corrective	PR.PS	4.1; 7.3
R-04	Least privilege, RBAC, separation of duties, reviews	Governance / Preventive	GV.RR; PR.AA	5.1; 6.8
R-05	Centralize guest logs and configure actionable alerts	Detective	DE.CM; DE.AE	8.2; 8.11

The course material referenced NIST CSF PR.AC, which is a CSF 1.1 category. This report uses NIST CSF 2.0, where identity and access outcomes are represented under PR.AA. Mappings show control intent and do not assert certification.

8. Risk Treatment Plan

ID	Action	Priority	Owner	Success measure	Status
M-01	Restrict RDP source to trusted IPv4 /32	P0	Cloud Admin	No Any source on TCP/3389	Complete
M-02	Replace direct RDP with Bastion, VPN/private access, or JIT	P0	Cloud Architect	No continuously exposed public admin port	Planned
M-03	Require MFA-capable centralized administrative authentication	P0	Identity Admin	MFA required where supported	Planned
M-04	Enable automated patch orchestration and compliance reporting	P1	Endpoint Admin	Scheduled patching and compliant status	Planned
M-05	Enable Tamper Protection and PUA blocking	P1	Security Admin	Warning states resolved	Planned
M-06	Collect guest security events in Log Analytics	P1	Cloud / SOC	Events centrally searchable	Planned
M-07	Configure alerts and test action-group delivery	P1	SOC	Test notification received	Planned
M-08	Review Owner access and implement least-privilege RBAC	P2	Subscription Admin	No unnecessary permanent Owner	Planned

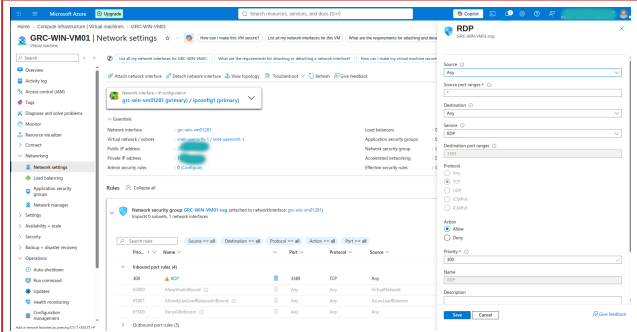
Residual risk statement

The trusted /32 restriction reduces exposure to arbitrary internet sources but does not address a compromised trusted endpoint, changing public IP addresses, credential theft, or a publicly routable management service. The strategic target remains private or Just-in-Time administrative access with MFA-capable centralized authentication.

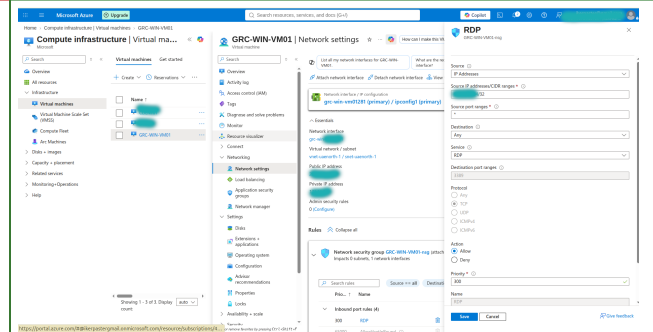
R-04 is temporarily accepted for this personal lab. Acceptance is not a recommendation for production use.

9. Mitigation Validation - RDP Before and After

Baseline evidence showed TCP/3389 allowed from Any source. After treatment, the source was changed to a trusted public IPv4 /32, source ports remained *, destination TCP/3389 remained Allow, and the sensitive address was redacted for publication.



Before: NSG RDP rule allowed source Any.

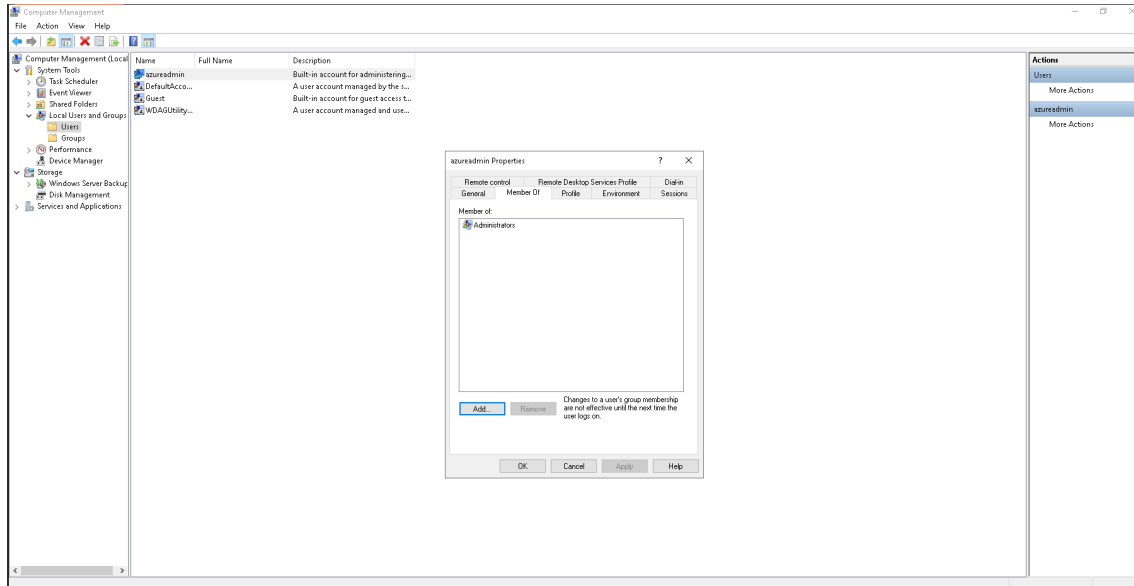


After: RDP source restricted to trusted IPv4 /32.

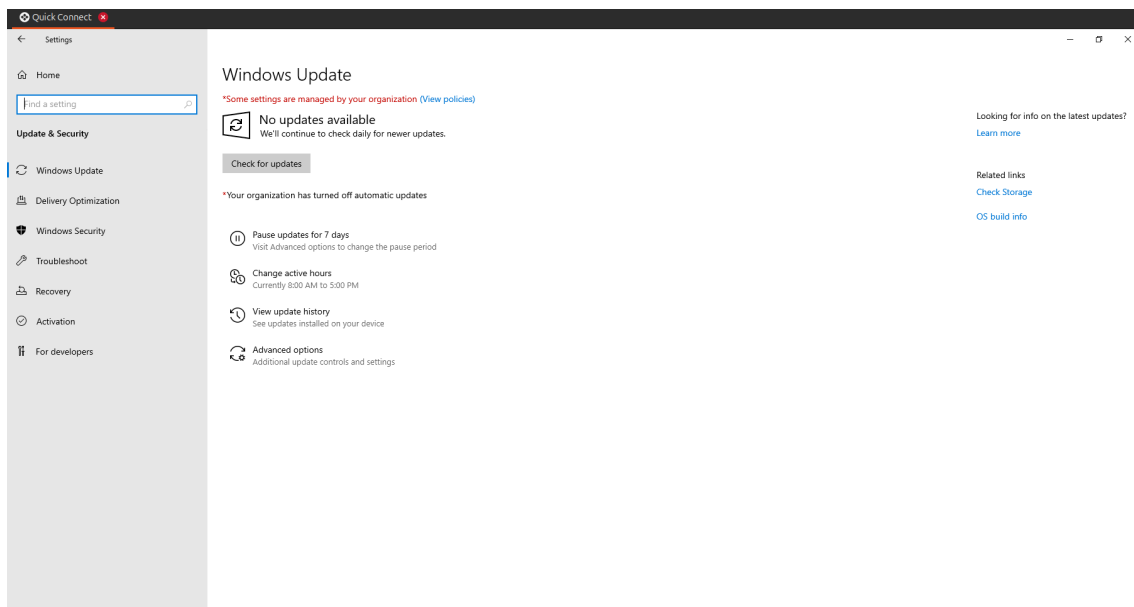
Validated outcome: R-01 likelihood reduced from 4 to 2. Impact remains 4. Residual score = 8/25 (Medium). Additional treatment is recommended.

10. Supporting Evidence Highlights

The complete evidence set is published in the repository evidence directory. The following screenshots support the highest-impact identity, endpoint, monitoring, and governance conclusions.



Identity: azureadmin is a member of local Administrators.



Endpoint: automatic updates were turned off by policy.

The screenshot shows the Azure Monitor interface for a virtual machine named GRC-WIN-VM01. The left sidebar contains navigation links for Overview, Activity log, Access control (IAM), Tags, Diagnose and solve problems, Resource visualizer, Connect, Networking, Settings, Availability + scale, Security, Backup + disaster recovery, Operations, and Monitoring. The Monitoring section is expanded, showing Alerts, Metrics, Diagnostic settings, Logs, Dashboards with Grafana, and Workbooks. The main content area displays 'Alerts (Not configured)' with a message to get notified on important monitoring events. Below this, there's a 'Metrics' section for 'CPU / Availability / Memory'. Three charts are shown: Availability (0.6 to 0.9), CPU Utilization % (60% to 90%), and Memory utilization % (0 to 90). A message at the bottom of the charts states 'No metrics detected. Confirm detailed metrics'.

Detection: Azure Monitor alerts were not configured.

The screenshot shows the Azure Access control (IAM) page for the 'Free Trial' subscription. The left sidebar contains navigation links for Overview, Activity log, Access control (IAM), Tags, Diagnose and solve problems, Security, Resource visualizer, Events, Resource groups, Resources, Cost Management, Billing, Settings, Monitoring, and Help. The main content area displays 'My access' and 'Check access' sections. Below these, there are buttons for 'Grant access to this resource' and 'Create a custom role'. On the right, the 'Role assignments' section shows a table with columns: Role, Description, Scope, Group assignment, and Condition. The table lists one assignment: Owner, Grants full access to manage all r..., This resource, --, and Add.

Governance: one Owner assignment at subscription scope.

11. Conclusion and Limitations

The assessment translated technical Azure and Windows observations into a prioritized risk register and actionable treatment plan. The highest risk was reduced through a validated NSG change. Remaining work focuses on private administrative access, MFA-capable centralized authentication, automated patching, endpoint hardening, centralized logging and alerting, and least-privilege RBAC.

This project demonstrates cloud security assessment, GRC analysis, evidence handling, control mapping, and executive risk communication. It does not represent a penetration test, audit opinion, certification, or guarantee that no additional risks exist.

References

- NIST Cybersecurity Framework 2.0 - <https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>
- CIS Critical Security Controls v8.1 - <https://www.cisecurity.org/controls/v8-1>
- Azure network security groups overview - <https://learn.microsoft.com/en-us/azure/virtual-network/network-security-groups-overview>
- Azure Monitor for virtual machines - <https://learn.microsoft.com/en-us/azure/azure-monitor/vm/vminsights-overview>
- Azure role-based access control overview - <https://learn.microsoft.com/en-us/azure/role-based-access-control/overview>

Prepared by Iker Paster | Cybersecurity and Cloud Security Portfolio